DIRECTIVE SUR LA SURVEILLANCE ET L'ANALYSE DES ÉVÉNEMENTS DE SÉCURITÉ

Avis de confidentialité

Ce document contient des informations qui sont destinées à l'usage exclusif de iA Groupe financier.

Sous réserve d'une approbation d'un représentant dûment autorisé de iA Groupe financier, toute reproduction de ce document, ou sa distribution à l'extérieur de son groupe autorisé d'utilisateurs est interdite.

Table des matières

1. Introduction 3
   1.1. Portée 3
   1.2. Contexte 3
   1.3. Définitions 3
2. Exigences de la directive 4
   2.1. Exigences relatives aux investigations numériques 4
   2.2. Exigences relatives à la gestion des menaces 5
   2.3. Exigences relatives à la gestion des vulnérabilités 5
   2.4. Exigences relatives à la surveillance et à l'analyse de la sécurité 6
3. Écarts et exceptions 7

Directive sur la surveillance et l'analyse des événements de sécurité	
Propriétaire	Chef de la sécurité de l'information (CISO)
Portée	Groupe
Objectif de la Directive	Définir les exigences en matière de gestion des menaces et des vulnérabilités, de surveillance de la sécurité et d'analyse des événements dans l'environnement technologique de iA Groupe financier.
Date de révision	s.o.
Autorité d'approbation	Comité directeur sur la sécurité de l'information (CDSI)
Date d'approbation	7 avril 2022
Date d'entrée en vigueur	7 avril 2022
Fréquence de révision	Tous les trois (3) ans ou à la suite de changements majeurs
Prochaine révision	2025-04

1. Introduction

1.1. Portée

La *Directive sur la surveillance et l'analyse des événements de sécurité* s'applique à iA Groupe financier, à ses employés, à ses fournisseurs de services et à ses sous-traitants, consultants et toute personne dont le travail est sous la responsabilité de la direction de la Société, sur laquelle la Société exerce un contrôle direct et qui utilise les actifs de iA Groupe financier.

1.2. Contexte

La Société doit établir un cadre de gestion de la sécurité de l'information complet et approuvé afin d'identifier de manière proactive les menaces et les vulnérabilités, d'enregistrer et de surveiller en permanence les événements liés à la sécurité, et d'investiguer de manière approfondie sur les incidents de sécurité, en remédiant à tout problème en temps voulu.

Le but de cette directive est de s'assurer que les objectifs entourant la gestion des menaces et des vulnérabilités, la surveillance de la sécurité et les investigations numériques sont définis afin de prévenir l'occurrence d'incidents perturbateurs pouvant affecter les informations et les parties prenantes de la société.

1.3. Définitions

« iA Groupe financier » ou « la Société » désigne iA Société financière inc. et ses filiales directes et indirectes, exerçant leurs activités sous le nom iA Groupe financier.

Les « journaux d'événements » ou les « journaux » sont des enregistrements d'un événement survenu dans les systèmes et les réseaux d'une organisation.

Le « profilage des menaces » fait référence au développement de profils pour les scénarios de menaces auxquels l'organisation est confrontée, permettant la mise en œuvre d'un programme de gestion proactive des incidents qui se concentre sur la composante menace des risques.

Un « test d'intrusion » désigne une méthodologie de test dans laquelle les évaluateurs, travaillant généralement sous des contraintes spécifiques, tentent de contourner ou de mettre en échec les dispositifs de sécurité d'un système d'information.

Une « vulnérabilité » est une faiblesse d'un système d'information, des procédures de sécurité du système, des contrôles internes ou de la mise en œuvre qui pourrait être exploitée ou déclenchée par une source de menace.

2. Exigences de la directive

2.1. Exigences relatives aux investigations numériques

La Société doit établir un processus pour traiter les incidents de sécurité de l'information ou d'autres événements qui nécessitent une investigation numérique, identifier les auteurs d'actes malveillants et préserver des preuves suffisantes pour engager des actions en justice contre eux si nécessaire. Plus précisément, la Société doit être en mesure de localiser, d'extraire, d'analyser et de protéger les données de ses actifs pour mener des investigations, pour déterminer les relations de cause à effet et pour servir de preuve à l'appui de mesures correctives internes ou devant un tribunal. Les exigences nécessaires à l'établissement d'un cadre pour l'analyse des investigations numériques sont énumérées ci-dessous :

a. Mettre en place une équipe d'investigations numériques, composée de membres désignés de l'équipe d'intervention en cas d'incident de cybersécurité (ÉRIC), chargée de fournir à la Société la capacité appropriée pour collecter, préserver et examiner les preuves au cours des investigations et pour communiquer et rendre compte des résultats de ces investigations.
b. Définir les rôles et les responsabilités des membres de l'équipe d'investigations numériques et leur fournir la formation et les outils spécialisés nécessaires pour accomplir leurs tâches.
c. Définir les seuils et les cas d'utilisation sur lesquels une investigation numérique doit être effectuée.
d. Définir les conditions dans lesquelles les investigations doivent être menées afin de garantir l'objectivité et l'indépendance des investigations tout en tenant compte des implications pour la vie privée, l'emploi et les droits individuels.
e. Définir les procédures de saisie et de conservation des preuves électroniques afin de s'assurer qu'elles restent légalement admissibles tout au long de l'investigation.
f. Activer les capacités de journalisation appropriées et tirer parti des contrôles d'accès des utilisateurs pour identifier l'utilisateur spécifique, la source et les points de destination du flux d'informations afin de permettre une reconstitution d'une investigation numérique des événements.
g. S'assurer que tous les journaux d'événements de sécurité sont conformes à un format standard et sont protégés par le chiffrement, le contrôle d'accès et la sauvegarde.

h. Conserver les journaux d'événements de sécurité et les preuves pour répondre aux exigences de conservation de la Société, éviter toute spoliation et soutenir d'éventuelles investigations numériques.
i. S'assurer que la Société peut prouver que toutes les preuves collectées n'ont pas été altérées et peut soutenir la nécessité d'une chaîne de possession pour démontrer qui a manipulé les preuves depuis le moment de la découverte jusqu'au moment de la procédure judiciaire.
j. Inspecter les sources informatiques et non informatiques pertinentes à chaque incident de sécurité de l'information.
k. Communiquer les progrès et les résultats de l'investigation numérique aux parties internes et externes concernées en respectant le principe du besoin de savoir.

2.2. Exigences relatives à la gestion des menaces

La Société doit combiner les renseignements sur les menaces avec des outils de sécurité et des analyses pour rechercher les menaces de manière proactive et créer des profils de menaces adaptés à son paysage de menaces. En restant à l'affût des dernières menaces de sécurité, la Société peut répondre rapidement à toute attaque potentielle et protéger ses systèmes et ses informations. Les exigences nécessaires à la collecte et à l'analyse des renseignements sur les menaces pour soutenir les décisions et les activités liées aux risques sont énumérées ci-dessous :

a. Définir les rôles et les responsabilités en matière de collecte, de triage et de communication des renseignements sur les menaces.
b. Collecter et regrouper les renseignements sur les menaces provenant de sources pertinentes et explicites, adaptées à l'environnement et au secteur d'activité de la Société.
c. Analyser continuellement les renseignements sur les menaces en corrélant différentes sources et en déterminant dans quelle mesure la Société est exposée au risque d'une attaque ciblée.
d. Intégrer les flux de renseignements sur les menaces aux outils de gestion et d'analyse des journaux de la Société afin d'enrichir leurs capacités d'alerte avec les informations les plus récentes.
e. Effectuer des exercices continus de chasse aux menaces sur les systèmes et les réseaux les plus susceptibles d'être ciblés.
f. Élaborer de multiples hypothèses d'attaque pour les systèmes sélectionnés à l'étude, sur la base des renseignements sur les menaces collectées.
g. Déterminer les profils de menace globaux de la Société en exploitant les informations issues des activités de chasse aux menaces.
   Mettre en œuvre des contrôles pour atténuer les menaces identifiées dans le profilage des menaces.

2.3. Exigences relatives à la gestion des vulnérabilités

La gestion des vulnérabilités est un élément clé de la planification de la gestion des risques et de la détermination de la mise en œuvre appropriée des contrôles de sécurité. La Société doit continuellement acquérir et évaluer de nouvelles informations afin d'identifier les vulnérabilités et prendre des mesures appropriées et opportunes pour y remédier. Le fait de remédier rapidement aux vulnérabilités permet d'éviter leur exploitation et de réduire la probabilité d'occurrence d'incidents de sécurité. Les exigences nécessaires pour assurer une évaluation et une remédiation adéquates des

vulnérabilités de sécurité affectant l'environnement technologique de la Société sont énumérées ci-dessous :

a. Établir une approche pour gérer les vulnérabilités en fonction des exigences en matière de risques et de conformité, en tenant compte des actifs concernés, des différents types et de la fréquence des évaluations des vulnérabilités.
b. Établir un processus formel de gestion des vulnérabilités permettant l'identification, l'évaluation, la remédiation et la reddition de compte sur les vulnérabilités de manière continue.
c. Identifier les vulnérabilités à partir de diverses sources et utiliser ces informations pour alimenter le processus de gestion des vulnérabilités.
d. Analyser les vulnérabilités identifiées et leur attribuer un niveau de sévérité en fonction de leur contexte.
e. Établir des objectifs de remédiation et définir des plans de remédiation pour traiter les vulnérabilités en fonction de leur niveau de sévérité.
f. Évaluer et gérer le risque de ne pas remédier à une vulnérabilité lorsque l'objectif de remédiation ne peut être atteint.
g. Partager les informations obtenues à partir du processus de gestion des vulnérabilités et des évaluations des contrôles de sécurité avec les parties prenantes concernées pour aider à éliminer les vulnérabilités similaires dans d'autres systèmes d'information.
h. Utiliser des mécanismes automatisés pour comparer les résultats des analyses de vulnérabilité dans le temps afin de déterminer l'efficacité et la rapidité de la remédiation des vulnérabilités.

2.4. Exigences relatives à la surveillance et à l'analyse de la sécurité

La Société doit utiliser des mécanismes de journalisation et des outils de surveillance et d'analyse de la sécurité pour enregistrer et surveiller les événements de sécurité dans les journaux. Les journaux doivent être stockés de manière centralisée, protégés contre les modifications non autorisées et analysés régulièrement. En activant la journalisation des événements, la Société peut identifier de manière proactive les menaces et soutenir les investigations numériques. Les exigences nécessaires à la journalisation, à la surveillance, à l'analyse et à l'établissement de rapports sur les actifs informationnels afin de détecter et de répondre efficacement aux événements de sécurité de l'information sont énumérées ci-dessous :

a. Envoyer les événements liés à la sécurité collectés à partir de tous les actifs pertinents vers un référentiel central afin qu'ils soient consommés et analysés par le système de gestion et d'analyse des journaux de la Société.
b. Consigner tous les accès des utilisateurs individuels aux informations confidentielles.
c. Configurer les actifs pour synchroniser le temps avec les sources de temps centralisées approuvées.
d. Enregistrer les journaux d'événements dans un format reconnu par l'industrie avec les attributs nécessaires tout en limitant la présence d'informations confidentielles, dans la mesure du possible.
e. Protéger les journaux d'événements et les systèmes de gestion des journaux à l'aide de contrôles d'accès, de gestion et de surveillance de l'intégrité, de contrôles de disponibilité et de résilience, de cryptographie forte et de protocoles de sécurité.

f. Identifier les événements pertinents liés à la sécurité et établir une bibliothèque de cas d'utilisation pour aider aux investigations et à la réponse aux événements.
g. Utiliser des outils automatisés pour prendre en charge l'analyse des événements en temps quasi réel.
h. Corréler les informations provenant de différents outils de surveillance, lorsque cela est possible, afin d'obtenir une vue plus complète de l'activité du système d'information et de révéler potentiellement des modèles d'attaque qui pourraient autrement passer inaperçus.
i. Générer des alertes lorsque des indicateurs de compromission sont détectés.
j. Maintenir et suivre un processus de conservation des journaux afin de garantir que les données des journaux d'événements sont conservées et disponibles conformément aux exigences de conservation de la Société.
k. Détruire sécuritaire les données des journaux d'événements conformément à leur niveau de sensibilité.

3. Écarts et exceptions

Dans les cas où cette directive n'est pas respectée, une demande de dérogation doit être remplie en suivant le processus de dérogation au cadre normatif de la sécurité de l'information.

Veuillez contacter l'équipe de sécurité de l'information < *DemandesSecuriteSI@ia.ca* > pour obtenir plus d'informations sur ce processus ou sur la directive, le cas échéant.